

Cybersecurity in Higher Education

Evidence review for progressive cyber defense under partial observability and capability constraints

Research working paper | 24 September 2026 | Prepared for undergraduate project scoping

Scope and evidence rule. This is a targeted, source checked scoping review, not a systematic review or a census of Sri Lankan universities. Academic studies, institutional survey findings, official guidance, and service descriptions are distinguished below. “Unknown” means the cited material does not establish the claim. Statements labelled inference are proposed interpretations to test.

Part 1 Executive summary

The problem is real, but its exact form in Sri Lankan universities remains unmeasured publicly. A higher education risk review identifies valuable and diverse assets and a fragmented threat surface [1]. A 2025 EDUCAUSE workforce study documents pressure on security and privacy staff, although its respondents should not be generalized to Sri Lanka [2]. Sri Lanka has a national strategy and LEARN operates a member CSIRT [3–5]; neither proves that individual universities have complete asset inventories, local SOC coverage, or a given maturity level. Sri Lankan student awareness studies address human behaviour, not institutional technical capability [6].

The strongest defensible contribution is to test a small, reproducible decision process that distinguishes “unknown” from “absent”, estimates feasible actions using local time and skill constraints, and revises priorities after discovery. The novelty claim is provisional: CSF profiles, CIS implementation groups, lightweight HEI frameworks, and partial observation defense models already cover important pieces [7–11]. An institution wide validated framework or regional SOC is beyond a 20–24 week study.

Part 2 Cybersecurity problems in universities

Universities combine student records, research, administrative systems, laboratories, teaching platforms and many independently managed endpoints. Ulven and Wangen synthesize assets, threats, actors and vulnerabilities across higher education literature; their 2021 review establishes diversity and exposure, but does not quantify current prevalence in Sri Lanka [1]. Openness supports academic work while decentralized ownership complicates inventory and coordinated remediation. These are recurring literature themes, not attributes demonstrated for every university.

Jisc's UK cyber impact study used its posture survey and interviews with 12 universities and four further education providers affected by attacks. It documents disruption and recovery experiences but selects affected institutions; it cannot yield the attack rate for all universities [12]. Phishing, credential theft, ransomware, vulnerable internet services and third party exposures deserve assessment as plausible scenarios, not an asserted ranking for Sri Lanka [1,12]. Laboratories, BYOD, cloud and legacy services should be recorded as separate ownership and observability domains during fieldwork.

Part 3 Current cybersecurity practices

Documented sector practice ranges from governance and self assessment to collaborative response. Jisc offers a tertiary education cyber self assessment and operates an NREN SOC and CSIRT [13,14]. REN ISAC offers sector threat sharing, peer assessments and a vendor assessment tool [15]. SURFcert coordinates incident support; SURFsoc is an additional monitoring service [16]. These examples establish

available models, not universal adoption. A local assessment should verify who owns inventory, scans, logs, backup tests, alerts, containment and recovery, and request evidence of operation rather than relying on policy existence.

Part 4 Resource constrained universities

A Western Balkan paper proposes a lightweight risk framework focused on learning management systems using penetration testing and controls [9]. It is direct evidence that constrained HEI design has prior art, but its LMS focus does not validate an institution wide roadmap. The 2025 EDUCAUSE workforce study reflects respondents' work pressures in its sampled higher education setting [2]. Limited budget, people, downtime windows and authority must therefore be measured separately: a nominally free control can require unavailable administration time, access, training or vendor support. This last claim is a design inference, to be tested in interviews.

Part 5 Developed and developing contexts

No comparable, representative cross country university dataset was identified in this scoped search. The table therefore distinguishes observed services from missing measurements; it does not rank countries.

Dimension	Well resourced sector examples	Developing contexts	Sri Lanka evidence	Research implication
Asset visibility	Jisc and REN ISAC offer assessment tools; campus completeness unknown	No representative measure found	No university wide baseline located	Measure coverage and confidence locally
Staffing and expertise	EDUCAUSE workforce respondents report pressures [2]	Varies; comparable sample absent	Institutional counts unknown	Record roles, hours and delegated responsibility
Budget and legacy	UK financial pressure noted by Jisc [17]	Context specific, unquantified here	University budgets/legacy inventory unknown	Use actual costs and change windows
Monitoring and SOC	Jisc SOC; SURFsoc optional [14,16]	Availability varies	LEARN CSIRT confirmed; campus SOC coverage unverified [4]	Separate shared coordination from local telemetry
Incident response	Jisc and SURF CSIRTs [14,16]	No shared baseline	LEARN CSIRT and national CERT exist [3,4]	Test reporting and escalation with permission
Governance and law	National/sector rules vary	Jurisdiction dependent	National strategy 2025–2029 [3]	Map institutional mandates separately
Threat intelligence and collaboration	REN ISAC MISP and peer assessment [15]	Uneven availability	LEARN member coordination [4]	Test actionable uptake, not mere membership
Awareness	Not uniform	Not uniform	Student studies exist [6]	Do not infer staff or institutional maturity

Part 6 Sri Lankan higher education

Direct university evidence: a 2020 journal study surveyed university students in Sri Lanka and found awareness alongside knowledge gaps concerning newer threats [6]. A University of Colombo entrant case study examines a narrower student cohort [18]. Neither measures institutional inventory, patching, staffing, budgets or incident response. LEARN states that it interconnects UGC funded state universities and other research and education organizations [5]. LEARN CSIRT describes proactive and reactive member assistance and procedures for member reports [4]. This supports availability of a sector contact point, not a measured level of member coverage or an institutional SOC.

National context: Sri Lanka CERT's published National Cyber Security Strategy 2025–2029 and national coordination role concern the country [3]. UGC's strategic plan refers to secure digital systems and a pilot survey of interconnection opportunities [19]; it is an intention, not evidence that university security controls were implemented. Publicly verifiable multi campus institutional maturity, staffing, budget and incident denominators were not established in this search. The defensible next research activity is a consent based institutional pilot and interviews with LEARN and campus IT teams, including explicit questions on service eligibility and telemetry.

Part 7 LEARN NREN and shared cybersecurity

LEARN CSIRT advertises incident coordination and information exchange for members [4]. UK Jisc runs sector SOC/CSIRT functions [14]; US REN ISAC shares indicators through MISP and offers assessments [15]; Dutch SURF distinguishes coordinated CSIRT support from the optional SURFsoc detection service [16]. Their governance, financing, service level, data sharing and legal environments differ. A Sri Lankan university might gain reporting, advisories and coordination through LEARN, but local inventory, response ownership and logging integration must be verified before claiming equivalent operational coverage. Shared SOC deployment is future work.

Part 8 Existing frameworks and maturity models

Model	Useful task	Assumptions and cost	Unknowns, sequence and fit
NIST CSF 2.0 [7]	Govern, Identify, Protect, Detect, Respond, Recover; current and target profiles	Requires local evidence, owners and tailoring	Profiles express gaps; do not optimize discovery under uncertainty
NIST 800 53 [20]	Detailed control catalogue	Large selection and implementation burden	Reference catalogue, not a campus roadmap
NIST 800 30 r1 [21]	Risk assessment and uncertainty discussion	Requires credible threat, impact and likelihood judgments	Supports analysis but no automatic feasible sequence
NIST 800 61 r3 [22]	Incident response in CSF 2.0	Needs defined response roles and processes	Relevant to escalation; not inventory completeness
CIS Controls v8.1 [8]	Specific safeguards and IG1 entry point	Even basic safeguards need asset ownership and operations	Already prioritizes by resources; key comparator
ISO 27001/27002 [23]	Management system and control guidance	Documentation, governance and audit effort	Flexible, but sequence is institution defined
COBIT [24]	Enterprise IT governance	Leadership and process capacity	Governance comparator, limited operational ranking
C2M2 v2.1 [25]	Capability maturity and investment discussion	Energy sector origin; extensive practices	Useful dimensions, needs HEI adaptation
Jisc self assessment [13]	Sector tailored posture survey	UK membership and context	Strong HEI baseline comparator; test accessibility locally
CMMC [26]	Contractual assurance in US defense supply chain	Specific procurement obligations	Include only if campus contract requires it

A maturity score measures documented process and capability, not breach probability. Pilot dimensions should include governance, assets, identity, vulnerabilities, logging, response, backups, third parties, staffing and budget. Score each with evidence level (observed, reported, unknown) and ownership; avoid averaging “unknown” into zero. Validate questions with local practitioners and compare answers against records and a small authorized technical sample.

Part 9 Partial observability

There are at least two distinct uncertainties: unknown assets and vulnerabilities before discovery; and hidden attacker state despite alerts. POMDP work commonly models the latter using belief distributions over compromise and noisy observations. An IEEE 2018 model treats dynamic defense with false and missed alerts [10]; Hu, Zhu and Liu model adaptive multistage defense using Bayesian attack graphs [11]. Sarraute and colleagues' foundational penetration testing work puts scans into a planning under uncertainty formulation, but from an attacker/tester perspective [27]. These models demonstrate technical prior art, yet typically need a network model, observation probabilities and action effects that a poorly mapped university may not possess. A small evidence confidence ledger and explicit value of discovery may be a more testable undergraduate baseline than a full POMDP.

Part 10 Capability and resource constraints

CIS Implementation Groups explicitly account for enterprise risk and resources [8], so resource aware prioritization itself is not novel. C2M2 addresses capability assessment [25], and NIST small organization guidance supports starting with modest security programs [28]. A potential distinction is to include prerequisites (who can perform a fix), staff hours, authorization, recurring monitoring cost and dependency on discovery in the decision rule. Compare any proposed rule with simpler baselines: risk only, CIS IG1 order, and expert ranking. Do not claim quantified risk reduction unless a defensible impact measure exists.

Part 11 Progressive cybersecurity improvement

CSF current and target profiles and tiers support gap identification and reassessment [7,29]. CIS IG1 supplies a staged on ramp [8]. Continuous improvement is therefore established. The testable question is whether selecting the next action with explicit uncertainty and feasible capability produces better decisions than those existing methods under a constrained campus scenario. Candidate cycle: evidence collection → uncertainty record → feasible candidate list → transparent ranking → authorized action → observed result → reassessment. This is a hypothesis for evaluation, not a validated architecture.

Part 12 Evidence matrix

Codes: Y = directly addressed; P = partially or indirectly addressed; N = not addressed in the source; ? = unavailable from the accessible source. "Relevance" is an assessment for this project. Source entries contain method, context, limits and direct links; the compact matrix is intended for screening and should be expanded from full texts before publication.

Citation	Country sample method	Domain and model	Resources observation priority progression HE	Limits and relevance
1 Ulven & Wangen 2021 [1]	Global HE literature; review	HE assets, threats, vulnerabilities	N/N/N/N; HE Y	Review not current prevalence; High
2 EDUCAUSE 2025 [2]	HE professionals; survey and focus groups	Staffing and workload	Y/N/N/N; HE Y	Respondent and regional bias; High
3 Kepuska & Tomasevic 2024 [9]	Western Balkans; LMS framework, penetration test	Lightweight LMS risk and controls	Y/N/P/P; HE Y	LMS scope; High
4 Jisc Cyber Impact 2020 [12]	UK affected institutions; survey and 16 interviews	Incident impact and recovery	P/N/N/P; HE Y	Selection bias, older; Medium
5 Jisc self assessment 2024 [13]	UK sector; institutional tool	Posture benchmarking	P/N/P/P; HE Y	Service, no outcome validation here; High

Citation	Country sample method	Domain and model	Resources observation priority progression HE	Limits and relevance
6 Sri Lankan student study 2020 [6]	Sri Lankan students; questionnaire	Awareness and new threat knowledge	N/N/N/N; HE Y	Students ≠ operations; Medium
7 Colombo cohort 2021 [18]	Single faculty entrants; case study	Awareness	N/N/N/N; HE Y	Single cohort; Low
8 LEARN CSIRT [4]	Sri Lankan NREN; service description	Member incident coordination	P/N/N/P; HE Y	Provision ≠ uptake; High
9 Sri Lanka strategy 2025–29 [3]	National policy	National cyber priorities	P/N/P/P; HE N	No campus capability measure; Medium
10 NIST CSF 2.0 [7]	General guidance	Profiles and risk outcomes	P/P/P/Y; HE N	Tailoring required; High
11 CIS IGs [8]	General practice guidance	Resource tiered safeguards	Y/N/Y/Y; HE N	Asset knowledge needed; High
12 C2M2 2.1 [25]	Energy sector model	Capability assessment	Y/N/P/Y; HE N	Sector transfer untested; Medium
13 POMDP IEEE 2018 [10]	Modeled networks; formal/experimental	Defense with noisy alerts	P/Y/Y/Y; HE N	Requires model parameters; High
14 Hu et al 2020 [11]	Attack graphs; learning model	Adaptive multistage defense	P/Y/Y/Y; HE N	Network knowledge assumptions; High
15 REN ISAC [15]	US sector; service description	Shared intelligence/assessments	P/N/P/P; HE Y	No local outcome inference; Medium
16 SURFcert/SURFsoc [16]	Dutch sector; service description	Shared response/detection	P/N/P/P; HE Y	Different service contract; Medium

Part 13 Research gap analysis

Well studied: generic risk and control frameworks, HEI risk categories, resource tiering, and formal defense under noisy monitoring [1,7,8,10,11]. Partially studied: lightweight HEI approaches and shared sector services [4,9,13–16]. Insufficiently established by the reviewed evidence: whether a low data, low staff institution can jointly rank discovery, remediation, monitoring and capability investment, update that order after each observation, and show better decisions in a Sri Lankan university setting. This is a bounded hypothesis, not proof that no such method exists. A systematic search and citation chaining may reveal closer prior art. The Sri Lankan empirical gap is particularly strong as a measurement need, but absence in this search is not proof of national absence.

Part 14 Candidate research questions

- RQ1: How accurately can a short, evidence graded questionnaire describe asset and response capability in one or two consenting Sri Lankan campuses?
- RQ2: Under fixed staff hours, how does an uncertainty and feasibility aware action ranking compare with risk only and CIS IG1 baselines in realistic university scenarios?
- RQ3: When does an extra discovery action change the top remediation or monitoring choice enough to justify its effort?
- RQ4: Which local response tasks can campus teams practically share with LEARN, and which require campus ownership?

Part 15 Candidate methodology

Use a scoping review with published search strings, inclusion rules, dates and a source ledger; preregister the fieldwork questions. Pilot a brief maturity instrument with two to five practitioners, revise ambiguous questions, and seek permission for one or two institutional assessments. Collect inventories, role

descriptions, ticket and alert samples only where authorized; remove identifiers. Build several synthetic or approved cyber range scenarios with hidden assets and finite work hours. Elicit costs and dependencies from practitioners, score independent expert priorities, and compare a transparent rule against risk only, CIS order and equal cost choices. Outcomes: rank agreement, feasible actions selected, discovery value, sensitivity to uncertain weights, and assessment burden. Do not run scans on campus systems without explicit authorization.

Direction	Data and complexity	Validation	20 to 24 week fit	Possible venue
Evidence graded assessment	Interviews and records; low to medium	Inter rater agreement and evidence audit	Core if access secured	HEI security or applied computing workshop
Uncertainty aware action ranking	Scenario graph, costs; medium	Baselines, sensitivity and expert review	Core in bounded scenarios	Applied cybersecurity conference
Full POMDP defense	Transition probabilities and telemetry; high	Simulation plus real calibration	Extension only if data ready	Security modeling venue
NREN service integration	Agreements, telemetry, governance; high	Operational pilot	Future work	NREN/CSIRT practice venue

Part 16 Feasibility over 20 to 24 weeks

Core: weeks 1–4 protocol, search and extraction; weeks 5–7 interviews, ethics and assessment design; weeks 8–11 small pilot and scenarios; weeks 12–16 ranking implementation and baselines; weeks 17–20 evaluation and sensitivity; weeks 21–24 writing and revision. Access and approval are schedule risks: if no institution participates by week 7, conduct an explicitly simulated study and frame Sri Lankan operational claims as unanswered. Extension: second institution, dashboard and small range exercise. Future work: production monitoring, shared SOC, causal measurement of incident reduction and nationwide representative survey. Publication is plausible as a transparent pilot or methods paper, contingent on rigorous baselines and candid limits, not guaranteed.

Part 17 Initial review paper structure

1 Introduction and bounded questions; 2 Review method and source quality; 3 HEI assets, threats and operational challenges; 4 Sri Lanka and comparable contexts; 5 Governance, NREN and shared response; 6 Frameworks and maturity instruments; 7 Partial knowledge and sequential defense; 8 Resources and feasible control selection; 9 Comparative synthesis matrix; 10 Supported gaps and alternative explanations; 11 Candidate methods and validation; 12 Limitations and conclusion. Keep empirical findings distinct from a proposed system.

Part 18 Recommended immediate next steps

- Register databases, search strings, publication windows, screening and exclusion criteria; search IEEE, ACM, Scopus or institutional access and citation chain the closest papers.
- Ask LEARN and two campus IT leads for an interview and public documents; verify incident coordination, logging access, authority and service boundaries.
- Design a short assessment with evidence, unknown and owner fields; pilot it before assigning maturity scores.
- Choose three bounded scenarios and obtain expert priorities; define baselines and evaluation criteria before coding.
- At week 7 decide with the supervisor whether real institutional access supports a campus pilot or whether the project should be presented as a simulation study.

References and direct links

- [1] Ulven, J. B., & Wangen, G. (2021). A Systematic Review of Cybersecurity Risks in Higher Education. *Future Internet* 13(2), 39. <https://doi.org/10.3390/fi13020039>
- [2] EDUCAUSE (2025). Cybersecurity and Privacy Workforce in Higher Education. <https://www.educause.edu/content/2025/2025-educause-cybersecurity-and-privacy-workforce-in-higher-education>
- [3] Sri Lanka CERT. National Cyber Security Strategy of Sri Lanka 2025–2029. https://cert.gov.lk/wp-content/uploads/policies/National_Cyber_Security_Strategy_of_Sri-Lanka.pdf
- [4] LEARN. LEARN CSIRT service. <https://www.ac.lk/service/csirt>
- [5] LEARN. About and member network. <https://www.learn.ac.lk/>
- [6] A Study of Cyber Security Issues in Sri Lanka (2020). *International Journal of Cyber Warfare and Terrorism* 10(3), 59–72. <https://doi.org/10.4018/IJCWT.2020070105>
- [7] NIST (2024). Cybersecurity Framework 2.0. <https://doi.org/10.6028/NIST.CSWP.29>
- [8] CIS. CIS Controls Implementation Groups. <https://www.cisecurity.org/controls/implementation-groups>
- [9] Kepuska, K., & Tomasevic, M. (2024). A lightweight framework for cyber risk management in Western Balkan higher education institutions. *PeerJ Computer Science* 10, e1958. <https://doi.org/10.7717/peerj-cs.1958>
- [10] A POMDP Approach to the Dynamic Defense of Large Scale Cyber Networks (2018). *IEEE Transactions on Information Forensics and Security* 13(10). <https://doi.org/10.1109/TIFS.2018.2819967>
- [11] Hu, Z., Zhu, M., & Liu, P. (2020). Adaptive Cyber Defense Against Multi Stage Attacks Using Learning Based POMDP. *ACM Transactions on Privacy and Security*. <https://doi.org/10.1145/3418897>
- [12] Jisc (2020). Cyber impact. <https://www.jisc.ac.uk/reports/cyber-impact>
- [13] Jisc (2024). Cyber security self assessment for tertiary education. <https://www.jisc.ac.uk/news/all/cyber-security-self-assessment-made-easier-for-uk-tertiary-education-and-research-organisations>
- [14] Jisc (2025). New security operations centre. <https://www.jisc.ac.uk/news/all/new-security-operations-centre-to-protect-uk-education-and-research>
- [15] REN ISAC. Overview and services. <https://www.ren-isac.net/what-we-do/Overview.html>
- [16] SURF. SURFcert and SURFsoc. <https://www.surf.nl/en/services/security/surfcert> ; <https://www.surf.nl/en/services/security/surfsoc>
- [17] Jisc (2026). Higher education sector leadership survey commentary. <https://www.jisc.ac.uk/blog/what-we-learned-from-our-tenth-higher-education-sector-leadership-survey>
- [18] Cybersecurity awareness among undergraduates at University of Colombo (2021). <https://ir.lib.pdn.ac.lk/items/dc090cf0-f879-4503-9102-e8b72077d104>
- [19] UGC Sri Lanka (2025). Strategic Plan 2025–2029. https://www.ugc.ac.lk/downloads/corporate_plan/Startergic%20Plan%202025-2029.pdf
- [20] NIST SP 800 53 Rev 5. <https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final>

- [21] NIST SP 800 30 Rev 1 (2012). <https://doi.org/10.6028/NIST.SP.800-30r1>
- [22] NIST SP 800 61 Rev 3 (2025). <https://doi.org/10.6028/NIST.SP.800-61r3>
- [23] ISO/IEC 27001:2022 overview. <https://www.iso.org/standard/27001>
- [24] ISACA COBIT overview. <https://www.isaca.org/resources/cobit>
- [25] US DOE (2022). C2M2 Version 2.1.
<https://www.energy.gov/sites/default/files/2022-06/C2M2%20Version%202.1%20June%202022.pdf>
- [26] US DoD CMMC program.
<https://business.defense.gov/Programs/Cyber-Security-Resources/Cybersecurity-Maturity-Model-Certification/>
- [27] Sarraute, C., Buffet, O., & Hoffmann, J. (2013). POMDPs Make Better Hackers.
<https://arxiv.org/abs/1307.8182>
- [28] NIST (2024). CSF 2.0 Small Business Quick Start Guide.
<https://www.nist.gov/publications/nist-cybersecurity-framework-20-small-business-quick-start-guide>
- [29] NIST (2024). Quick Start Guide for CSF Tiers. <https://csrc.nist.gov/pubs/sp/1302/final>